



KAYNA KAYNA PAY

# Comprendre Kayna Kayna Pay

*Le produit, son fonctionnement et ses garde-fous*

Ce document explique ce que fait Kayna Kayna Pay, comment la plateforme est construite et pourquoi elle est construite ainsi. Il s'adresse à qui doit reprendre le projet, l'expliquer, ou décider de son avenir.

|            |                                          |
|------------|------------------------------------------|
| Public     | Équipe technique, direction, partenaires |
| Version    | 1.0 — août 2026                          |
| Complément | Guide d'utilisation · L'essentiel        |

« *Kayan si djineh koy yan gandji* » — *faire petit n'empêche pas d'avancer*

# Sommaire

---

- 1 Le projet en une phrase** Ce que Kayna Kayna Pay fait, et pour qui
- 2 Le vocabulaire** Les six mots qui reviennent partout
- 3 L'architecture** Trois morceaux, une seule base de données
- 4 Le parcours du client** De l'inscription à la remise du produit
- 5 Le versement, pièce par pièce** La machine à états qui protège l'argent
- 6 Les trois règles d'or de l'argent** Ce qui ne se négocie jamais
- 7 La base de données** Les tables et ce qu'elles garantissent
- 8 La sécurité** Mots de passe, jetons, double facteur, rôles
- 9 Comment on sait que ça marche** Le test de bout en bout
- 10 Les pièges à connaître** Les erreurs déjà commises, et leur correctif
- 11 Ce qui reste à faire** La feuille de route après le MVP
- 12 Résumé en une page** À relire avant une démonstration

# 1. Le projet en une phrase

Kayna Kayna Pay permet à quelqu'un d'acheter un bien en le payant petit à petit, par mobile money, et de le recevoir une fois le montant complété.

Ce n'est pas du crédit : personne n'avance d'argent, personne ne s'endette. C'est l'inverse — on épargne d'abord, on reçoit ensuite. Le nom vient du zarma : « kayna kayna », petit à petit.

| Ce que ce n'est pas                           | Ce que c'est                                      |
|-----------------------------------------------|---------------------------------------------------|
| Du crédit à la consommation                   | Une épargne affectée à un achat précis            |
| Un paiement en plusieurs fois après livraison | Un paiement en plusieurs fois avant livraison     |
| Un portefeuille électronique                  | Un compteur par achat, qui ne sert qu'à cet achat |
| Un opérateur mobile money                     | Un service qui s'appuie sur NITA, Amana et Wave   |

## LE MODÈLE ÉCONOMIQUE

Le partenaire fixe son prix. La plateforme ajoute 5 % de commission et affiche le total au client. Le client ne voit qu'un prix, celui qu'il paiera — rien ne s'ajoute à la fin.

Exemple : une moto à 640 000 F chez le vendeur est affichée **672 000 F**. À la livraison, le vendeur touche ses 640 000 F, la plateforme garde 32 000 F.

## 2. Le vocabulaire

Six mots reviennent dans le code, dans les écrans et dans les conversations. Les confondre est la première source de malentendu ; ils sont donc employés partout avec le même sens.

| Mot          | Ce que ça désigne                                                           | Ce que ça ne désigne pas                                           |
|--------------|-----------------------------------------------------------------------------|--------------------------------------------------------------------|
| Achat        | L'engagement d'un client sur un produit : le prix est figé à son ouverture. | Une commande déjà payée.                                           |
| Portefeuille | Le compteur d'un achat : la somme des versements validés pour cet achat.    | Un porte-monnaie électronique réutilisable.                        |
| Versement    | Une tentative de dépôt : un montant, un opérateur, une référence unique.    | De l'argent reçu — tant qu'il n'est pas validé, rien n'est acquis. |
| Écriture     | La ligne comptable créée quand un versement est validé.                     | Un enregistrement modifiable.                                      |
| Référence    | Le code court que le client recopie dans le motif du transfert.             | Un numéro de compte.                                               |
| Partenaire   | Le vendeur dont les produits figurent au catalogue.                         | Un actionnaire ou un apporteur d'argent.                           |

**POURQUOI LA DISTINCTION VERSEMENT / ÉCRITURE COMPTE**

Un versement peut être rejeté ; une écriture, jamais. Le solde d'un portefeuille se recalcule toujours à partir des écritures, jamais à partir des versements. C'est cette séparation qui empêche un dépôt douteux de gonfler un compteur.

### 3. L'architecture

Le projet tient en trois morceaux, et un seul détient la vérité.

| Morceau              | Technologie                                   | Rôle                                                                                                    |
|----------------------|-----------------------------------------------|---------------------------------------------------------------------------------------------------------|
| L'application mobile | Expo / React Native (JavaScript)              | Ce que le client a dans la main. Elle n'a aucune règle métier : elle affiche ce que le serveur lui dit. |
| Les espaces web      | Next.js (pages)                               | L'espace d'administration et l'espace partenaire, dans un navigateur.                                   |
| Le serveur           | Next.js (routes API) + Socket.io + PostgreSQL | La seule autorité. Toutes les règles d'argent y sont, et nulle part ailleurs.                           |

#### LA RÈGLE QUI STRUCTURE TOUT LE RESTE

Aucune règle métier ne vit dans l'application mobile. Si demain quelqu'un modifie l'application pour s'attribuer 100 000 F, le serveur refusera : c'est lui qui calcule, valide et journalise. L'application n'est qu'une fenêtre.

#### 3.1 Le dossier, fichier par fichier

Les emplacements à connaître avant de toucher quoi que ce soit :

| Chemin                        | Ce qu'on y trouve                                                                         |
|-------------------------------|-------------------------------------------------------------------------------------------|
| plateforme/lib/versements.js  | <b>Le cœur. Machine à états, validation, recalcul du portefeuille. À lire en premier.</b> |
| plateforme/lib/auth.js        | Jetons, mots de passe, cookies de session, double facteur.                                |
| plateforme/lib/db.js          | Connexion PostgreSQL, transactions, paramètres de la plateforme.                          |
| plateforme/pages/api/         | Une route = un fichier. Le nom du fichier est l'adresse.                                  |
| plateforme/db/migrations/     | Le schéma, en migrations numérotées et empreintées.                                       |
| plateforme/scripts/smoke.js   | Le test de bout en bout : 25 critères d'acceptation.                                      |
| mobile/src/ecrans/            | Un écran = un fichier.                                                                    |
| mobile/src/composants/Base.js | La bibliothèque de composants de l'application.                                           |
| mobile/src/theme.js           | Couleurs, tailles, espacements : la source unique du design.                              |

## 4. Le parcours du client

---

Sept étapes, de l'inscription à la remise. Chacune correspond à un écran de l'application et à une route du serveur.

- 1 **Inscription.** Numéro de téléphone, nom, mot de passe, acceptation des conditions. Un code à six chiffres arrive par SMS et vérifie le numéro. Sans cette vérification, aucun compte n'est actif.
- 2 **Choix d'un produit.** Le catalogue affiche des prix commission comprise. La fiche produit propose un simulateur : « à tant par jour, vous terminez dans tant de temps ».
- 3 **Ouverture de l'achat.** Le prix est figé à cet instant. Si la commission change ensuite, cet achat n'est pas touché.
- 4 **Versement.** Le client choisit un montant (dès 100 F) et un opérateur. Le serveur lui renvoie un numéro de dépôt et une référence unique.
- 5 **Dépôt réel.** Le client envoie l'argent par mobile money en indiquant la référence dans le motif, puis déclare le dépôt dans l'application.
- 6 **Validation.** Un administrateur vérifie la réception sur le compte de la plateforme et valide au montant réellement reçu. Le portefeuille est crédité, le client est notifié en temps réel.
- 7 **Remise.** Quand le portefeuille atteint le prix total, l'achat passe « complété ». La remise s'organise avec le partenaire, qui est réglé à la livraison confirmée.

### LE POINT DE FRICTION PRINCIPAL

Entre l'étape 5 et l'étape 6, l'argent est parti du téléphone du client mais n'est pas encore inscrit à son portefeuille. C'est la minute où il doute. Tout est fait pour réduire cette angoisse : référence bien visible, minuteur de dix minutes, notification instantanée, et surtout la garantie qu'un dépôt réel n'est jamais perdu — au pire il passe « en vérification ».

## 5. Le versement, pièce par pièce

Le versement est la seule chose qui crée de l'argent dans le système. Il est donc traité comme une machine à états : cinq états, des transitions autorisées explicitement, et rien d'autre.

| État                   | Ce qu'il signifie                                         | Peut aller vers                   |
|------------------------|-----------------------------------------------------------|-----------------------------------|
| <b>initie</b>          | Le client a demandé un versement. Aucune somme n'a bougé. | en_attente                        |
| <b>en_attente</b>      | Le client déclare avoir déposé. L'équipe doit vérifier.   | valide · rejete · en_verification |
| <b>en_verification</b> | Le minuteur de dix minutes a expiré sans décision.        | valide · rejete                   |
| <b>valide</b>          | Le dépôt est confirmé. Une écriture est créée.            | — (définitif)                     |
| <b>rejete</b>          | Le dépôt n'a pas été retrouvé. Un motif est obligatoire.  | — (définitif)                     |

### 5.1 Ce qui se passe à la validation

La validation est une seule transaction de base de données. Soit tout réussit, soit rien ne change — il n'existe aucun état intermédiaire où l'argent serait à moitié inscrit :

- le versement passe à « validé », avec le montant réellement reçu ;
- une écriture est ajoutée au portefeuille de l'achat ;
- le solde est recalculé à partir de toutes les écritures ;
- si le solde atteint le prix total, l'achat passe « complété » ;
- le client et, le cas échéant, le partenaire sont notifiés ;
- la transition est journalisée avec son auteur et l'heure.

#### POURQUOI LE MONTANT VALIDÉ PEUT DIFFÉRER DU MONTANT DÉCLARÉ

Le client déclare 1 000 F mais dépose 950 F : l'administrateur valide 950 F. Le portefeuille reflète l'argent réellement reçu, pas l'intention. C'est le seul écart toléré, et il est visible dans l'historique du client.

### 5.2 Un seul versement ouvert à la fois

Un achat ne peut pas avoir deux versements en cours. La règle n'est pas écrite dans le code applicatif mais **dans la base de données**, sous forme d'index unique partiel :

```
CREATE UNIQUE INDEX versement_actif_unique
ON versements (achat_id)
WHERE statut IN ('initie', 'en_attente');
```

Deux requêtes simultanées ne peuvent donc pas créer deux versements : la seconde est refusée par PostgreSQL lui-même. Une règle écrite seulement dans le code se contourne ; une contrainte de base, non.

## 6. Les trois règles d'or de l'argent

Trois principes gouvernent tout le code qui touche à l'argent. Ils ne se discutent pas et se vérifient à chaque relecture.

### RÈGLE 1 — CE QUI EST VALIDÉ EST DÉFINITIF

Un versement validé ne peut être ni modifié, ni supprimé, par personne — pas même par le super-administrateur. Une erreur se corrige par une écriture de correction, jamais par une réécriture. L'historique reste vrai.

### RÈGLE 2 — LE SOLDE SE RECALCULE, IL NE S'INCRÉMENTE PAS

Le portefeuille n'est jamais mis à jour par addition. Il est recalculé à partir de la somme des écritures validées. Un incrément raté laisserait un solde faux pour toujours ; un recalcul, non.

### RÈGLE 3 — LES INTERDITS VIVENT DANS LA BASE

Unicité du versement actif, unicité des références, cohérence des montants : ce sont des contraintes PostgreSQL. Le code applicatif les rappelle pour donner un message clair, mais c'est la base qui refuse.

### LE TEST QUI VÉRIFIE LES TROIS RÈGLES À LA FOIS

Le test de bout en bout compare, en fin de parcours, le solde du portefeuille à la somme des écritures validées. S'ils diffèrent d'un seul franc, le test échoue. C'est le filet de sécurité le plus important du projet.



## 7. La base de données

PostgreSQL, une douzaine de tables. Voici celles qu'il faut connaître pour comprendre le reste.

| Table                     | Ce qu'elle contient                                     | Ce qu'elle garantit                                    |
|---------------------------|---------------------------------------------------------|--------------------------------------------------------|
| <b>users</b>              | Clients, administrateurs, partenaires — avec leur rôle. | Un numéro de téléphone = un compte.                    |
| <b>produits</b>           | Le catalogue : prix partenaire et prix affiché.         | Le prix affiché est figé à l'ouverture d'un achat.     |
| <b>achats</b>             | L'engagement d'un client sur un produit.                | Le prix total ne bouge plus.                           |
| <b>versements</b>         | Les tentatives de dépôt et leur état.                   | Un seul versement ouvert par achat ; référence unique. |
| <b>ecritures</b>          | Les lignes comptables des versements validés.           | Jamais modifiées, jamais supprimées.                   |
| <b>journal_versements</b> | Chaque transition d'état, avec auteur et horodatage.    | On peut toujours reconstituer qui a fait quoi.         |
| <b>audit</b>              | Les actions sensibles hors versements.                  | Traçabilité des changements de paramètres.             |
| <b>parametres</b>         | Commission, versement minimum, numéros de dépôt.        | Modifiable sans redéploiement.                         |

### 7.1 Les migrations

Le schéma n'est jamais modifié à la main. Chaque changement est un fichier numéroté dans db/migrations/, appliqué par un script qui garde l'empreinte SHA-256 de chaque migration déjà passée. Modifier une migration déjà appliquée est donc détecté, pas silencieusement ignoré.

```
npm run db:migrer      # applique les migrations manquantes
npm run verifier       # contrôle Node, dépendances, .env, base, schéma
```

## 8. La sécurité

Cinq mécanismes, chacun répondant à une menace précise.

| Mécanisme                          | Contre quoi il protège                                                                                                         |
|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| Mots de passe hachés (bcrypt)      | Une fuite de la base ne livre aucun mot de passe en clair.                                                                     |
| Jetons signés (JWT)                | Un jeton fabriqué ou modifié est rejeté : la signature ne correspond plus.                                                     |
| Double facteur des administrateurs | Un mot de passe d'administrateur volé ne suffit pas : un code SMS est exigé, et le jeton intermédiaire n'ouvre aucune session. |
| Cookie httpOnly + SameSite=Strict  | Le jeton des espaces web n'est pas lisible en JavaScript et ne part pas sur un site tiers.                                     |
| Contrôle de rôle sur chaque route  | Un client ne peut pas appeler une route d'administration, même en connaissant son adresse.                                     |

LE DÉTAIL QUI FAIT LA DIFFÉRENCE SUR LE DOUBLE FACTEUR

Après le mot de passe, le serveur renvoie un jeton portant la marque `etape: "2fa"`. La fonction qui autorise les routes refuse tout jeton portant cette marque. Deux preuves sont donc réellement nécessaires : sans cela, le premier jeton aurait suffi à tout ouvrir.

## 9. Comment on sait que ça marche

Une seule commande, **npm run smoke**, rejoue le parcours complet contre un serveur réel et une base réelle, et vérifie 25 critères.

| Famille                  | Exemples de critères vérifiés                                                                               |
|--------------------------|-------------------------------------------------------------------------------------------------------------|
| Inscription et connexion | Les conditions d'utilisation sont obligatoires ; le numéro est vérifié par SMS.                             |
| Double facteur           | Le mot de passe seul n'ouvre aucune session ; le jeton intermédiaire non plus ; un mauvais code est refusé. |
| Versements               | Instructions complètes ; un seul versement actif ; validation au montant réel ; rejet motivé obligatoire.   |
| Temps réel               | L'administrateur voit le versement arriver ; le client est notifié de la décision.                          |
| Minuteur                 | Un versement expiré passe « en vérification » et reste validable.                                           |
| Comptabilité             | Le solde égale exactement la somme des écritures validées.                                                  |
| Habilitations            | Aucune route n'est accessible sans le rôle approprié.                                                       |
| Traçabilité              | Chaque transition d'état est journalisée.                                                                   |

**CE QUE CE TEST NE REMPLACE PAS**

Il vérifie les règles, pas l'expérience. Le rendu des écrans, la lisibilité d'un message d'erreur ou la clarté d'une référence de dépôt se contrôlent à l'œil, sur un vrai téléphone.

## 10. Les pièges à connaître

Ces erreurs ont réellement été commises pendant la construction du projet. Elles sont listées ici pour ne pas être refaites.

| Le piège                               | Ce qui se passe                                                                  | Le correctif                                                        |
|----------------------------------------|----------------------------------------------------------------------------------|---------------------------------------------------------------------|
| Incrémenter le solde                   | Un incrément raté laisse un portefeuille faux pour toujours.                     | Recalculer depuis les écritures, à chaque fois.                     |
| Faire confiance au montant déclaré     | Le client déclare 5 000 F et dépose 500 F.                                       | L'administrateur valide au montant réellement reçu.                 |
| Écrire la commission en dur            | Le catalogue et l'API finissent par afficher deux prix différents.               | Une seule source : le paramètre en base.                            |
| Remplacer le thème de navigation       | L'application plante au démarrage : la barre d'onglets perd sa table de polices. | Compléter le thème par défaut, ne jamais le remplacer.              |
| Perdre le numéro de dépôt à la reprise | Un client qui revient sur un versement initié ne sait plus où envoyer l'argent.  | La consultation d'un versement renvoie aussi ses instructions.      |
| Un message d'erreur vide               | « Migration interrompue — » ne dit rien de ce qui manque.                        | Diagnostiquer le code d'erreur et donner la commande de réparation. |

## 11. Ce qui reste à faire

---

Le MVP couvre le parcours complet. Voici ce qui viendra ensuite, par ordre d'importance.

| Chantier                      | Pourquoi                                                                                                               | Ordre de grandeur |
|-------------------------------|------------------------------------------------------------------------------------------------------------------------|-------------------|
| Passerelle SMS réelle         | Les codes s'affichent aujourd'hui dans les journaux du serveur : suffisant en développement, impossible en production. | Quelques jours    |
| Rapprochement automatique     | La validation est manuelle. Un relevé opérateur permettrait de pré-valider les dépôts qui correspondent.               | Quelques semaines |
| Gestion autonome du catalogue | Les partenaires consultent leurs produits mais ne les modifient pas encore.                                            | Quelques semaines |
| Notifications push            | Aujourd'hui le temps réel ne fonctionne que si l'application est ouverte.                                              | Quelques jours    |
| Stockage partagé des limites  | L'anti-abus est en mémoire : il ne tient pas sur plusieurs serveurs.                                                   | Une journée       |

## 12. Résumé en une page

---

À relire avant une démonstration ou une reprise du projet.

### LE PRODUIT

Épargner petit à petit par mobile money pour recevoir un bien. Ni crédit, ni dette. Commission de 5 % déjà comprise dans le prix affiché.

### L'ARCHITECTURE

Une application mobile Expo, deux espaces web Next.js, un serveur Next.js + Socket.io, une base PostgreSQL. Toutes les règles d'argent sont sur le serveur.

### LE CŒUR

Le versement : cinq états, des transitions explicites, une validation en une seule transaction, un journal de chaque changement.

### LES GARDE-FOUS

Ce qui est validé est définitif. Le solde se recalcule depuis les écritures. Les interdictions sont des contraintes de base de données.

### LA PREUVE

**npm run smoke** : 25 critères d'acceptation rejoués contre un serveur et une base réels.

« *Kayan si djineh koy yan gandji* » — *faire petit n'empêche pas d'avancer.*